ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN

KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG

PROPOSAL Đề tài:

Cloud API-Based Network Application Security for Small Company Services

BỘ MÔN: MẬT MÃ HỌC

Giảng viên hướng dẫn:

TS. Nguyễn Ngọc Tự

LỚP: NT209.Q22.ANTT

Nhóm thực hiện:

1. Nguyễn Tấn Danh - MSSV: 24520262
2. Nguyễn Thị Tuyết Nhi - MSSV: 24521263
3. Nguyễn Quốc Trường - MSSV: 24521896

Năm học: 2025 – 2026

Mục lục

1. Tóm tắt đề tài 4
2. Ngữ cảnh 4
   2.1 Thực trạng hiện nay 4
   2.2 Tại sao cần đặt bảo mật API lên hàng đầu? 5
3. Đối tượng nghiên cứu 6
4. Tài sản cần bảo vệ 7
5. Rủi ro bảo mật 8
6. Mục tiêu bảo mật 8
7. Mục tiêu nghiên cứu 10
8. Phạm vi thực hiện 11
9. Các bên liên quan 12
   9.1 End User 12
   9.2 Administrator 13
   9.3 Internal Service / Service Account 14
   9.4 External Partner 15
   9.5 Identity Provider / Authentication Authority 16
   9.6 API Gateway / Edge Security Layer 17
   9.7 Backend Service Owner / System Operator 18
   9.8 Data Owner 19
   9.9 Data User 20
   9.10 Cloud / Infrastructure Provider 21
10. Kiến trúc hệ thống 22
   10.1 Kiến trúc tổng quan 22
   10.2 Các thành phần chính 22
      10.2.1 Lớp Khách hàng (Client) 22

10.2.2 Lớp Xác thực (Identity) 23
10.2.3 Lớp API Gateway 23
10.2.4 Lớp Xử lý nghiệp vụ (Business Service) 23
10.2.5 Giao tiếp nội bộ giữa các service (Internal Service Communication) 23
10.2.6 Lớp Dữ liệu (Data Layer) 24
10.2.7 Logging, Audit và Secrets Management 24
11. Tech Stack dự kiến 25

BÁO CÁO CHI TIẾT

1. Tóm tắt đề tài

Đề tài tập trung vào việc thiết kế, triển khai và đánh giá một hệ thống dịch vụ mạng theo hướng API-first trên nền tảng cloud dành cho các công ty nhỏ. Nội dung chính của đề tài là xây dựng một mô hình bảo mật toàn diện cho API và hạ tầng mạng, bao gồm xác thực và phân quyền người dùng, quản lý token, bảo mật giao tiếp giữa các dịch vụ, phân tách mạng, giới hạn lưu lượng truy cập, giám sát nhật ký và phát hiện bất thường. Bên cạnh đó, đề tài còn hướng đến việc kiểm thử và gia cố hệ thống trước các nguy cơ phổ biến như BOLA, đánh cắp token, SSRF, lộ khóa API và giả mạo webhook. Mục tiêu cuối cùng là đề xuất một giải pháp bảo mật có tính thực tiễn, chi phí hợp lý, dễ vận hành và phù hợp với điều kiện nguồn lực hạn chế của doanh nghiệp nhỏ.

2. Ngữ cảnh

2.1 Thực trạng hiện nay

Hiện nay, hầu hết các nghiệp vụ trọng yếu của doanh nghiệp đều vận hành dựa trên API:

- Tích hợp đa nền tảng: Kết nối đồng bộ hệ thống CRM, ERP với các nền tảng đám mây hàng đầu như AWS, Azure hoặc Google Cloud, giúp chuẩn hóa luồng dữ liệu liên thông, loại bỏ các "ốc đảo thông tin" (data silos) và tối ưu hóa hiệu suất khai thác tài nguyên số.
- Tối ưu hóa trải nghiệm khách hàng: Tích hợp trực tiếp các giải pháp thanh toán, vận chuyển và mạng xã hội vào hệ sinh thái ứng dụng, tạo ra quy trình trải nghiệm "không điểm chạm", từ đó thúc đẩy tỷ lệ chuyển đổi và gia tăng giá trị vòng đời khách hàng.
- Vận hành hệ thống Multi-cloud: Điều phối dữ liệu luân chuyển linh hoạt giữa các môi trường đám mây khác nhau, đảm bảo tính sẵn sàng cao và duy trì sự ổn định của hoạt động kinh doanh trước mọi kịch bản sự cố hạ tầng.

Trong bối cảnh chuyển đổi số, các công ty nhỏ ngày càng phụ thuộc nhiều vào API để cung cấp dịch vụ cho ứng dụng web, mobile, hệ thống quản trị nội bộ hoặc kết nối với bên thứ ba. Tuy nhiên, khác với các doanh nghiệp lớn, nhóm doanh nghiệp này thường không có đội ngũ an ninh mạng chuyên sâu cũng như

ngân sách đủ lớn để triển khai các giải pháp bảo mật phức tạp. Và hơn hết, chỉ một sự cố liên quan đến API như rò rỉ token, lộ API key hoặc truy cập trái phép vào dữ liệu khách hàng cũng có thể gây ra tổn thất lớn về tài chính, uy tín và khả năng duy trì hoạt động kinh doanh.

2.2 Tại sao cần đặt bảo mật API lên hàng đầu?

Một sai sót nhỏ trong cấu hình API có thể dẫn đến những cuộc khủng hoảng quy mô lớn mà chi phí khắc phục thường vượt xa mức đầu tư cho hệ thống bảo mật ban đầu.

1. **Tính tuân thủ pháp lý - Áp lực không thể ngó lơ**

Trong bối cảnh Việt Nam đang siết chặt quản lý dữ liệu số, việc lỏng lẻo trong bảo mật API có thể khiến doanh nghiệp đối mặt với các rủi ro pháp lý nghiêm trọng:

- Nghị định 13/2023/NĐ-CP: Quy định khắt khe về bảo vệ dữ liệu cá nhân. Bất kỳ sự cố rò rỉ dữ liệu nào qua cổng API đều có thể dẫn đến án phạt hành chính nặng nề, thậm chí là đình chỉ hoạt động kinh doanh.
- Các tiêu chuẩn quốc tế: Đối với các doanh nghiệp đa quốc gia hoặc doanh nghiệp làm việc với đối tác nước ngoài, việc tuân thủ các chứng chỉ như GDPR (Châu Âu), PCI DSS (Thanh toán thẻ) hay ISO 27001 là điều kiện bắt buộc để duy trì hợp đồng.

2. **Bảo vệ uy tín thương hiệu - Tài sản vô hình nhưng vô giá**

Dữ liệu khách hàng bị rao bán trên các diễn đàn hacker không chỉ là mất mát thông tin, mà là mất đi niềm tin.

- Đối với ngành Tài chính - Ngân hàng (BFSI) hay Bán lẻ (Retail), niềm tin là nền tảng của lợi nhuận. Một vụ bê bối rò rỉ dữ liệu qua API có thể khiến khách hàng rời bỏ hệ thống ngay lập tức để chuyển sang đối thủ cạnh tranh.
- Khủng hoảng truyền thông sau sự cố bảo mật thường kéo dài và tốn kém hơn rất nhiều so với việc đầu tư vào một hạ tầng kết nối an toàn ngay từ đầu.

3. **Bài toán kinh tế: Phòng bệnh hơn chữa bệnh**

Dưới góc độ tài chính, đầu tư cho bảo mật API cần được xem là một khoản chi phí đầu tư (CAPEX/OPEX) thông minh để tránh các tổn thất không lường trước:

- Chi phí xử lý sự cố: Bao gồm phí thuê chuyên gia điều tra, chi phí phục hồi hệ thống, và các khoản bồi thường khách hàng.
- Chi phí cơ hội: Hệ thống API bị tấn công dẫn đến đình trệ vận hành (Downtime). Đối với các doanh nghiệp sản xuất hoặc thương mại điện tử, mỗi giờ hệ thống ngừng hoạt động đồng nghĩa với việc mất đi hàng tỷ đồng doanh thu.

4. **Tầm nhìn chiến lược về "Hệ sinh thái an toàn"**

Các doanh nghiệp hiện đại không chỉ xây dựng sản phẩm, họ xây dựng hệ sinh thái. Khi doanh nghiệp mở rộng kết nối với các đối tác bên thứ ba qua API, họ cũng đồng thời "nhập khẩu" rủi ro từ đối tác đó.

- Lãnh đạo cần đảm bảo rằng mọi mắt xích trong chuỗi liên kết đều phải đáp ứng các tiêu chuẩn an toàn chung.
- Việc lựa chọn một hạ tầng kết nối đám mây có tính bảo mật cao không chỉ giúp bảo vệ nội bộ mà còn tạo ra một "hành lang an toàn" cho toàn bộ đối tác trong hệ sinh thái của doanh nghiệp.

3. Đối tượng nghiên cứu

Đối tượng nghiên cứu chính của đề tài là hệ thống ứng dụng mạng vận hành theo mô hình API-first trên cloud dành cho doanh nghiệp nhỏ, trong đó trọng tâm là các API công khai hoặc nội bộ phục vụ cho web app, mobile app, microservices và các tích hợp với bên thứ ba. Đề tài xem xét toàn bộ chuỗi thành phần tham gia vào quá trình xử lý yêu cầu từ phía client đến backend, bao gồm client, API Gateway, Identity Provider, backend microservices, hệ thống quản lý khóa bí mật, công cụ logging và monitoring, cũng như quy trình CI/CD liên quan đến việc phát triển và triển khai hệ thống.

Ngoài ra, đề tài còn nghiên cứu các cơ chế bảo vệ đối với những nguy cơ thường gặp trong môi trường API hiện đại, bao gồm lỗi phân quyền quá mức cho đối tượng, xác thực không an toàn, lộ dữ liệu quá mức cần thiết, lạm dụng truy cập, giả mạo webhook, SSRF, cũng như rủi ro phát sinh từ chuỗi cung ứng phần mềm và quy trình CI/CD.

→ Đối tượng nghiên cứu bao gồm API và toàn bộ kiến trúc kỹ thuật, các điểm kiểm soát an ninh có liên quan trực tiếp đến việc cung cấp, bảo vệ và vận hành dịch vụ API trên cloud.

4. Tài sản cần bảo vệ

Trong phạm vi nghiên cứu của đề tài, tài sản được phân thành 4 nhóm chính cần được bảo vệ:

- Nhóm thứ nhất là dữ liệu đơn hàng và dữ liệu người dùng. Đây là nhóm tài sản gắn trực tiếp với các API nghiệp vụ như *GET /orders/{id}*, *GET /orders*, hoặc các API hồ sơ cá nhân. Nếu không được bảo vệ đúng mức, kẻ tấn công có thể lợi dụng lỗ hổng BOLA để truy cập đơn hàng không thuộc quyền sở hữu, hoặc khai thác excessive data exposure để thu thập các thông tin nhạy cảm như email, trạng thái nội bộ, thuộc tính hệ thống hay các dữ liệu nghiệp vụ không nên trả về cho client. Vì vậy, tính bí mật, toàn vẹn và đúng phạm vi truy cập của dữ liệu đơn hàng là tài sản cốt lõi cần được bảo vệ.
- Nhóm thứ hai là token, phiên đăng nhập và thông tin xác thực. Access token, refresh token, session identifier, service token và các thông tin liên quan đến xác thực đều là tài sản có giá trị bảo mật cao. Khi xảy ra token misuse hoặc token replay, kẻ tấn công có thể sử dụng token sai vai trò, sai phạm vi, dùng lại token hết hạn hoặc tái sử dụng token đã bị lộ để truy cập vào các API nhạy cảm. Do đó, hệ thống phải bảo vệ chặt chẽ vòng đời token, tính hợp lệ của token, quyền gắn với token và khả năng chống tái sử dụng trái phép.
- Nhóm thứ ba là các API nhạy cảm và cơ chế phân quyền của hệ thống. Các route như API xem chi tiết đơn hàng, API quản trị, API nội bộ hoặc các endpoint thay đổi trạng thái đơn hàng đều là tài sản logic quan trọng. Nếu cơ chế kiểm tra quyền không đầy đủ, người dùng thường có thể gọi nhầm hoặc cố tình truy cập vào các API chỉ dành cho admin hoặc service nội bộ. Vì vậy, ngoài việc bảo vệ dữ liệu, hệ thống còn phải bảo vệ chính quyền truy cập vào chức năng nghiệp vụ, bảo đảm mỗi actor chỉ được gọi đúng API phù hợp với vai trò của mình.
- Nhóm thứ tư là webhook endpoint và tính toàn vẹn của dữ liệu callback từ bên thứ ba. Trong bối cảnh hệ thống có tích hợp thanh toán hoặc vận chuyển, các webhook là điểm vào đặc biệt nhạy cảm. Nếu hệ thống không kiểm tra chữ ký HMAC, timestamp, replay hoặc idempotency một cách đầy đủ, kẻ tấn công có thể giả mạo callback để cập nhật sai trạng thái đơn hàng, tạo giao dịch giả hoặc làm sai lệch quy trình xử lý nghiệp vụ. Vì vậy, webhook không chỉ là một endpoint kỹ thuật mà còn là tài sản

liên quan trực tiếp đến tính xác thực và tính toàn vẹn của luồng nghiệp vụ liên hệ với đối tác ngoài.

- Nhóm thứ năm là tính sẵn sàng của hệ thống và tài nguyên xử lý API. Với rủi ro rate abuse, kẻ tấn công có thể gửi số lượng lớn request vào login endpoint hoặc public API nhằm brute force, tiêu tốn CPU, bộ nhớ, kết nối database và tài nguyên mạng. Khi đó, dù dữ liệu chưa bị lộ hay bị sửa, hệ thống vẫn có thể mất khả năng phục vụ người dùng hợp lệ. Vì vậy, khả năng sẵn sàng của dịch vụ, hiệu năng xử lý request và tài nguyên hạ tầng cũng là một loại tài sản quan trọng cần được bảo vệ.

5. Rủi ro bảo mật

Trong các hệ thống ứng dụng mạng dựa trên API triển khai trên nền tảng cloud, rủi ro bảo mật lớn nhất xuất phát từ việc API trở thành điểm truy cập trung tâm giữa người dùng, dịch vụ nội bộ và các hệ thống bên thứ ba. Khi API không được bảo vệ chặt chẽ, kẻ tấn công có thể khai thác lỗ hổng để truy cập trái phép dữ liệu, giả mạo yêu cầu, chiếm đoạt thông tin xác thực hoặc làm gián đoạn hoạt động của hệ thống. Đối với doanh nghiệp nhỏ, các rủi ro này càng nghiêm trọng vì nguồn lực vận hành an ninh thường hạn chế, trong khi mức độ phụ thuộc vào API ngày càng cao.

Trong phần mô phỏng và kiểm thử, nhóm tập trung vào 5 rủi ro ưu tiên sau:

- Broken Object Level Authorization (BOLA) trên Orders API.
- Broken Function Level Authorization / Token misuse đối với Admin API.
- Excessive Data Exposure ở các endpoint trả về object nghiệp vụ.
- Webhook Forgery / Replay tại webhook endpoint.
- Rate Abuse / Brute Force / Request Flooding trên public API và bề mặt đăng nhập.

6. Mục tiêu bảo mật

Mục tiêu bảo mật của đề tài là bảo đảm hệ thống quản lý đơn hàng qua API trên nền tảng cloud có khả năng bảo vệ dữ liệu, kiểm soát truy cập đúng quyền, duy trì tính toàn vẹn của luồng nghiệp vụ và bảo đảm tính sẵn sàng của dịch vụ trước các rủi ro bảo mật đã xác định. Các mục tiêu này được xây dựng trực tiếp từ kiến trúc hệ thống, các tài sản cần bảo vệ và năm rủi ro trọng yếu mà nhóm lựa chọn để phân tích và mô phỏng.

Các mục tiêu bảo mật bao gồm:

- Bảo đảm tính bí mật và đúng phạm vi truy cập của dữ liệu người dùng và dữ liệu đơn hàng. Hệ thống phải ngăn chặn việc người dùng đã đăng nhập nhưng vẫn có thể truy cập trái phép vào dữ liệu không thuộc quyền sở hữu của mình, đặc biệt đối với các API như GET /orders/{id} hoặc các endpoint trả về thông tin cá nhân. Điều này đòi hỏi cơ chế kiểm tra quyền ở mức tài nguyên phải được thực hiện đầy đủ tại service, thay vì chỉ dựa vào trạng thái đăng nhập hoặc dữ liệu do client cung cấp.
- Bảo đảm tính hợp lệ và an toàn của cơ chế xác thực, phân quyền và sử dụng token. Hệ thống phải bảo vệ access token, refresh token, session và các thông tin xác thực liên quan, đồng thời ngăn chặn việc sử dụng token sai vai trò, sai phạm vi, hết hạn hoặc bị tái sử dụng trái phép. Mục tiêu bảo mật ở đây là chỉ cho phép token hợp lệ, đúng quyền và còn hiệu lực được sử dụng để truy cập API, đặc biệt với các route nhạy cảm như */admin/**.
- Hạn chế tối đa việc rò rỉ dữ liệu không cần thiết qua phản hồi của API. Hệ thống phải bảo đảm rằng các response chỉ chứa đúng các trường dữ liệu cần thiết cho client, không làm lộ các thông tin nhạy cảm hoặc thông tin nội bộ như email, internal flags, password hash hoặc các thuộc tính chỉ phục vụ cho xử lý phía backend. Mục tiêu này nhằm bảo vệ tính bí mật của dữ liệu và giảm khả năng kẻ tấn công thu thập thông tin để phục vụ các bước khai thác tiếp theo.
- Bảo đảm tính xác thực và toàn vẹn của các callback từ đối tác bên ngoài. Đối với webhook endpoint, hệ thống phải xác minh rõ nguồn gửi, nội dung request và tính duy nhất của sự kiện trước khi chấp nhận xử lý. Điều này nhằm ngăn chặn tình huống kẻ tấn công giả mạo callback từ đối tác thanh toán hoặc vận chuyển để thay đổi trạng thái đơn hàng hoặc gây sai lệch nghiệp vụ.
- Bảo đảm tính sẵn sàng của hệ thống trước các hành vi lạm dụng truy cập. Hệ thống phải có khả năng chống lại brute force, request flooding và rate abuse tại login endpoint hoặc public API, từ đó tránh tình trạng cạn kiệt tài nguyên, tăng độ trễ hoặc gián đoạn dịch vụ đối với người dùng hợp lệ. Đây là mục tiêu quan trọng để bảo vệ khả năng vận hành liên tục và ổn định của hệ thống.
- Bảo đảm khả năng giám sát, truy vết và hỗ trợ ứng phó sự cố bảo mật. Hệ thống cần ghi log và audit đầy đủ đối với các sự kiện truy cập, xác thực, từ chối quyền, gọi API nhạy cảm, webhook và các bất thường liên quan đến token hoặc lưu lượng truy cập. Mục tiêu của nội dung này là giúp

phát hiện sớm hành vi tấn công, hỗ trợ điều tra sự cố và nâng cao hiệu quả kiểm soát an ninh trong quá trình vận hành.

7. Mục tiêu nghiên cứu

Mục tiêu tổng quát của đề tài là nghiên cứu, thiết kế và đánh giá một mô hình bảo mật cho hệ thống ứng dụng mạng vận hành theo kiến trúc API-first trên nền tảng cloud dành cho doanh nghiệp nhỏ. Mô hình này cần bảo đảm khả năng bảo vệ dữ liệu, kiểm soát truy cập, hạn chế các rủi ro tấn công phổ biến vào API, đồng thời vẫn phù hợp với điều kiện thực tế về chi phí, nhân lực vận hành và khả năng triển khai của doanh nghiệp quy mô nhỏ.

Đề tài bao gồm các mục tiêu cụ thể sau:

- Nghiên cứu kiến trúc bảo mật phù hợp cho hệ thống API trên cloud trong bối cảnh doanh nghiệp nhỏ, hướng đến việc phân tích các thành phần cốt lõi của một hệ thống API hiện đại, bao gồm client, API Gateway, Identity Provider, backend services, cơ chế quản lý khóa bí mật, logging, monitoring và quy trình CI/CD. Trên cơ sở đó, đề tài xác định vai trò của từng thành phần trong việc bảo vệ hệ thống và xây dựng một mô hình kiến trúc có tính khả thi, dễ vận hành và dễ mở rộng.
- Xây dựng cơ chế xác thực, phân quyền và kiểm soát truy cập an toàn cho hệ thống API, tập trung vào việc áp dụng các giải pháp như xác thực người dùng, quản lý token, phân quyền theo vai trò hoặc theo thuộc tính, kiểm tra quyền truy cập ở mức tài nguyên và bảo vệ các API nhạy cảm. Mục tiêu của nội dung này là bảo đảm rằng mỗi người dùng hoặc mỗi thành phần dịch vụ chỉ được phép truy cập đúng dữ liệu và đúng chức năng nghiệp vụ mà mình được cấp quyền.
- Xác định và phân tích các tài sản quan trọng cần được bảo vệ trong hệ thống, bao gồm dữ liệu đơn hàng và dữ liệu người dùng, token và thông tin xác thực, các API nhạy cảm cùng cơ chế phân quyền, webhook endpoint và dữ liệu callback từ đối tác, cũng như tính sẵn sàng của hệ thống và tài nguyên xử lý API. Việc nhận diện rõ các nhóm tài sản là cơ sở để xây dựng biện pháp phòng vệ phù hợp và lựa chọn trọng tâm kiểm thử bảo mật.
- Phân tích và mô phỏng các rủi ro bảo mật trọng yếu đối với hệ thống API. Trong phạm vi đề tài, nhóm tập trung vào năm rủi ro chính gồm: Broken Object Level Authorization (BOLA), token misuse hoặc token replay, excessive data exposure, webhook forgery/replay, và rate abuse

hoặc brute force trên public API. Mục tiêu của phần này là làm rõ cơ chế phát sinh của từng rủi ro, mức độ ảnh hưởng đến hệ thống, cũng như cách thức khai thác có thể xảy ra trong môi trường thực tế.

- Đề xuất và đánh giá các biện pháp bảo mật phù hợp để giảm thiểu các rủi ro đã xác định. Đề tài không chỉ dừng ở mức phân tích lý thuyết mà còn hướng đến việc lựa chọn các biện pháp bảo vệ có thể áp dụng trong thực tế, chẳng hạn như kiểm tra ownership ở mức tài nguyên để ngăn BOLA, quản lý vòng đời token chặt chẽ để chống token replay, giới hạn dữ liệu phản hồi nhằm tránh excessive data exposure, xác thực webhook bằng HMAC và chống replay, cũng như áp dụng rate limiting để hạn chế lạm dụng truy cập.
- Bảo đảm tính thực tiễn của mô hình bảo mật đối với doanh nghiệp nhỏ. Bên cạnh yêu cầu về an toàn, đề tài còn hướng tới việc xem xét khả năng áp dụng mô hình trong môi trường thực tế, đặc biệt dưới các ràng buộc về chi phí đầu tư, chi phí vận hành, nguồn lực nhân sự và nhu cầu tích hợp với hệ sinh thái đối tác. Đây là mục tiêu quan trọng nhằm bảo đảm rằng giải pháp được đề xuất không chỉ đúng về mặt kỹ thuật mà còn phù hợp với điều kiện triển khai của các doanh nghiệp nhỏ trong quá trình chuyển đổi số.

8. Phạm vi thực hiện

Đề tài được đặt trong bối cảnh doanh nghiệp nhỏ triển khai dịch vụ dựa trên API trên nền tảng cloud. Đây là nhóm doanh nghiệp bị hạn chế về ngân sách, nhân sự kỹ thuật và năng lực vận hành an ninh chuyên sâu nên các giải pháp được đề xuất trong đề tài không chỉ cần bảo đảm an toàn mà còn phải dễ triển khai, dễ quản trị và phù hợp với điều kiện thực tế của doanh nghiệp nên đề tài được thực hiện trong các phạm vi sau:

- Phạm vi đầu tiên là phạm vi về chi phí và nguồn lực vận hành. Những doanh nghiệp nhỏ thì nên ưu tiên các giải pháp managed service, serverless hoặc những thành phần có chi phí vận hành thấp như managed API Gateway, managed IdP, cloud KMS và WAF dùng sẵn, nên đề tài không hướng tới một hệ thống quá phức tạp hoặc đòi hỏi đội ngũ vận hành lớn, mà tập trung vào mô hình bảo mật có thể triển khai với nguồn lực hạn chế nhưng vẫn đạt hiệu quả hợp lý.

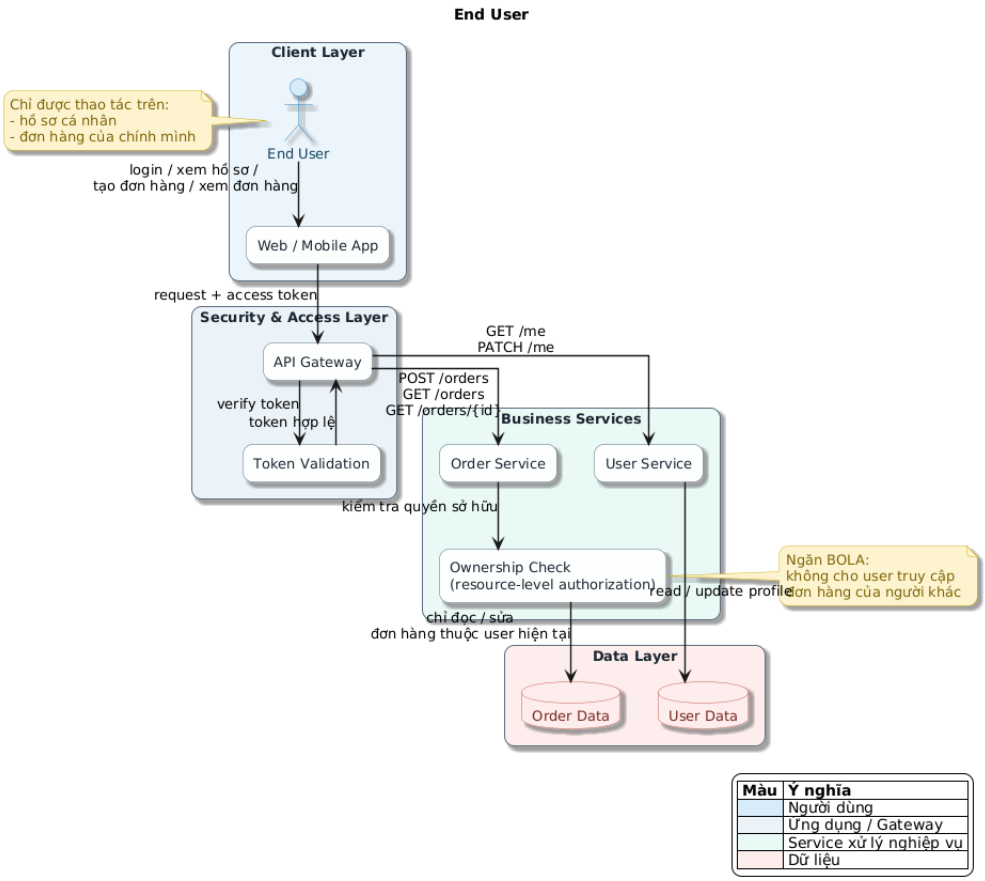
- Phạm vi thứ hai là phạm vi về triển khai. Hệ thống trong đề tài chỉ được xây dựng dưới dạng môi trường thử nghiệm có kiểm soát trên Docker, đảm bảo tính khả thi và tính học thuật trong quá trình thực hiện đề tài.
- Phạm vi thứ tư là phạm vi về kiến trúc hệ thống. Phạm vi kiến trúc của đề tài bao gồm các thành phần trực tiếp tham gia vào luồng truy cập và bảo vệ hệ thống quản lý đơn hàng qua API, gồm: Client (Web/Mobile/Admin), API Gateway, Identity Provider (IdP), các backend service như User Service, Order Service, Admin Service, Webhook Service, cơ chế xác thực service-to-service, cơ sở dữ liệu PostgreSQL, Logging/Audit và Secrets/KMS, tập trung vào kiến trúc xử lý yêu cầu qua API, xác thực, phân quyền, kiểm soát truy cập và bảo vệ dữ liệu; không đi sâu vào giao diện người dùng hay hạ tầng phần cứng triển khai chi tiết.
- Phạm vi thứ năm là phạm vi ràng buộc về an toàn và đạo đức. Toàn bộ hoạt động pentest, fuzzing và mô phỏng tấn công được cam kết chỉ được thực hiện trên hạ tầng thí nghiệm hoặc trên mục tiêu đã được cho phép, không được quét hay kiểm thử lên dịch vụ của bên thứ ba, không sử dụng bí mật thật của môi trường production trong demo, đồng thời sử dụng dữ liệu tổng hợp và làm sạch log trước khi chia sẻ.

9. Các bên liên quan

Trong hệ thống quản lý đơn hàng qua API trên nền tảng cloud, **các bên liên quan** là những chủ thể trực tiếp hoặc gián tiếp tham gia vào quá trình truy cập, xử lý, quản trị, xác thực và bảo vệ dữ liệu của hệ thống. Việc xác định đầy đủ các bên liên quan giúp làm rõ vai trò, phạm vi quyền hạn và trách nhiệm bảo mật của từng thành phần, từ đó làm cơ sở cho việc thiết kế cơ chế xác thực, phân quyền và kiểm soát truy cập phù hợp.

9.1 End User

End User là người dùng cuối của hệ thống, truy cập thông qua ứng dụng web hoặc mobile để đăng nhập, xem hồ sơ cá nhân, tạo đơn hàng, theo dõi trạng thái đơn hàng và chỉ được phép thao tác trên dữ liệu thuộc về chính mình. Đây là nhóm tác nhân chính sử dụng các API nghiệp vụ như /me, /orders, /orders/{id}. Về mặt bảo mật, End User là đối tượng cần được xác thực đầy đủ và bị ràng buộc chặt bởi cơ chế phân quyền ở mức tài nguyên, nhằm ngăn chặn các rủi ro như truy cập nhầm dữ liệu của người khác hoặc khai thác lỗ hổng BOLA.

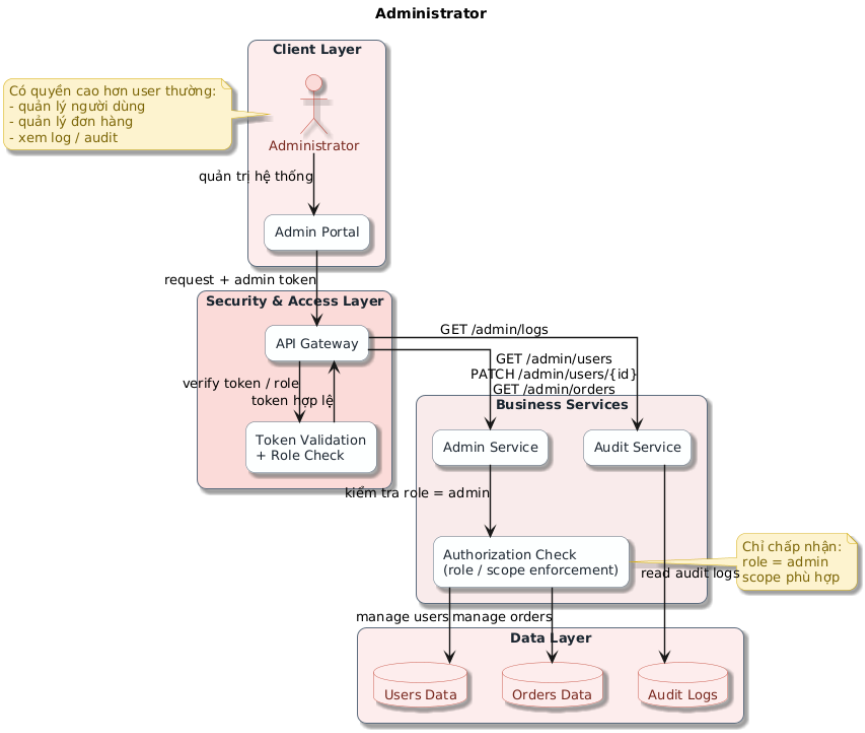


Hình 9. 1 - End User

9.2 Administrator

Administrator là quản trị viên của hệ thống, có trách nhiệm quản lý người dùng, phân quyền, giám sát hoạt động hệ thống, truy cập log/audit và sử dụng các API quản trị như /admin/*. So với người dùng thông thường, Administrator có phạm vi quyền lớn hơn và có thể truy cập vào nhiều dữ liệu hoặc chức năng nhạy cảm hơn.

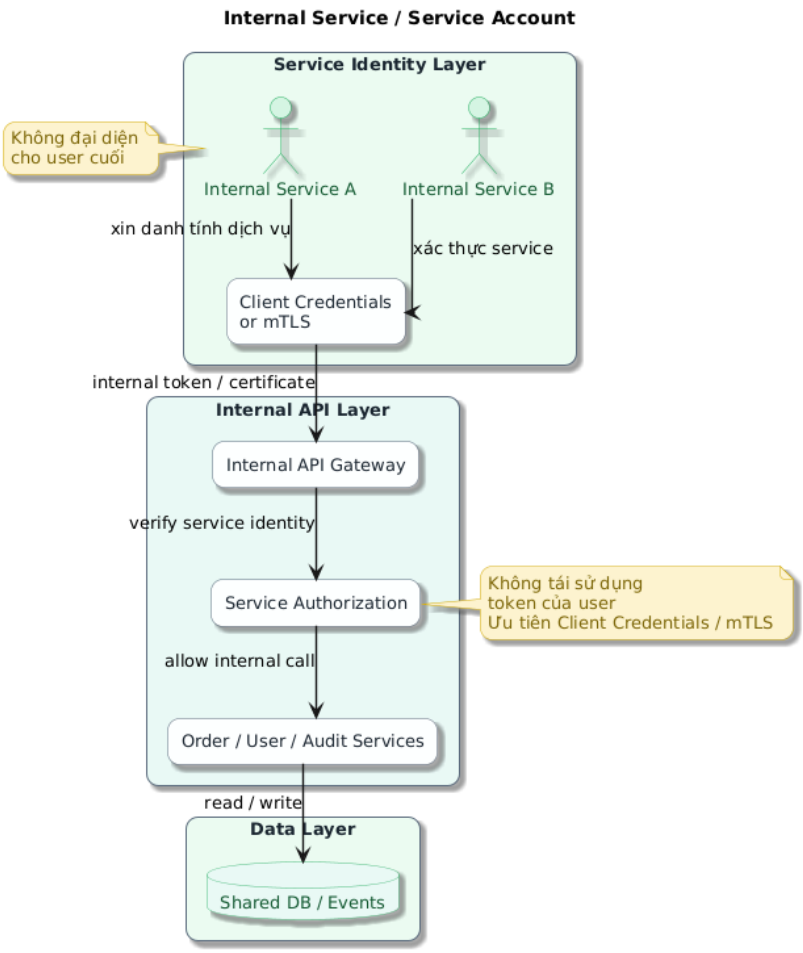
Do có đặc quyền cao, đây là nhóm cần được kiểm soát đặc biệt nghiêm ngặt trong cơ chế authorization, nhằm tránh tình trạng leo thang đặc quyền hoặc lạm dụng quyền quản trị.



Hình 9. 2 - Adminstator

9.3 Internal Service / Service Account

Internal Service hoặc Service Account là các dịch vụ nội bộ trong hệ thống backend giao tiếp với nhau qua API để xử lý nghiệp vụ, chẳng hạn như quản lý người dùng, xử lý đơn hàng, ghi log kiểm toán hoặc xử lý webhook. Nhóm này không đại diện cho người dùng cuối mà sử dụng một danh tính dịch vụ riêng. Trong kiến trúc của hệ thống, các service nội bộ nên xác thực bằng Client Credentials hoặc mTLS, thay vì tái sử dụng access token của người dùng. Đây là bên liên quan quan trọng vì nếu trust boundary giữa các service không được kiểm soát tốt, rủi ro lạm dụng nội bộ hoặc mở rộng phạm vi tấn công trong backend sẽ tăng lên đáng kể.

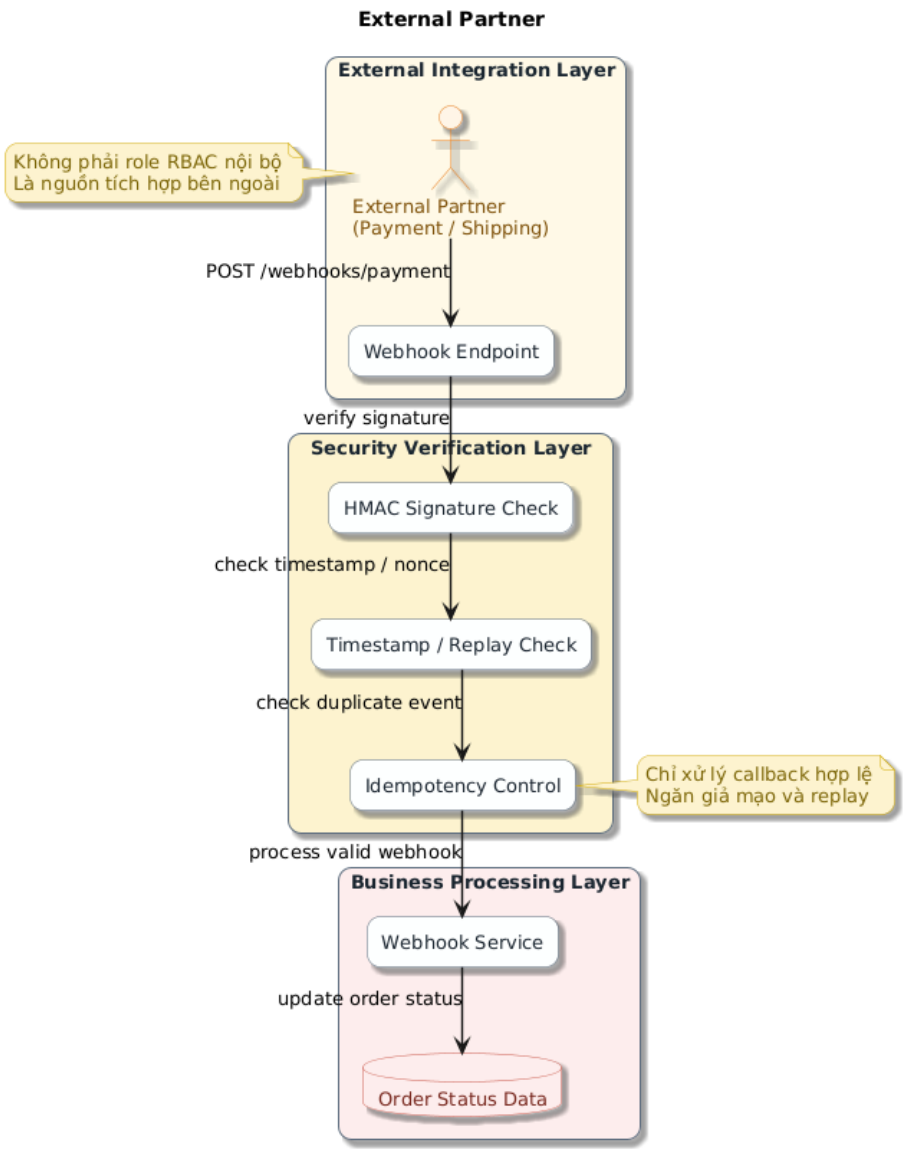


Hình 9. 3 - Internal Service / Service Account

9.4 External Partner

External Partner là các hệ thống bên thứ ba, ví dụ như cổng thanh toán hoặc đơn vị vận chuyển, gửi callback hoặc webhook đến hệ thống để cập nhật trạng thái giao dịch hoặc trạng thái đơn hàng. Đây không phải là một vai trò nội bộ trong mô hình RBAC, mà là một nguồn tích hợp bên ngoài.

Do đó, External Partner không được tin cậy mặc định mà phải được xác thực thông qua các cơ chế chuyên biệt như HMAC signature, timestamp/replay check và idempotency control. Việc xác định đúng vai trò của nhóm này có ý nghĩa quan trọng trong việc bảo vệ webhook endpoint và duy trì tính toàn vẹn của luồng nghiệp vụ.

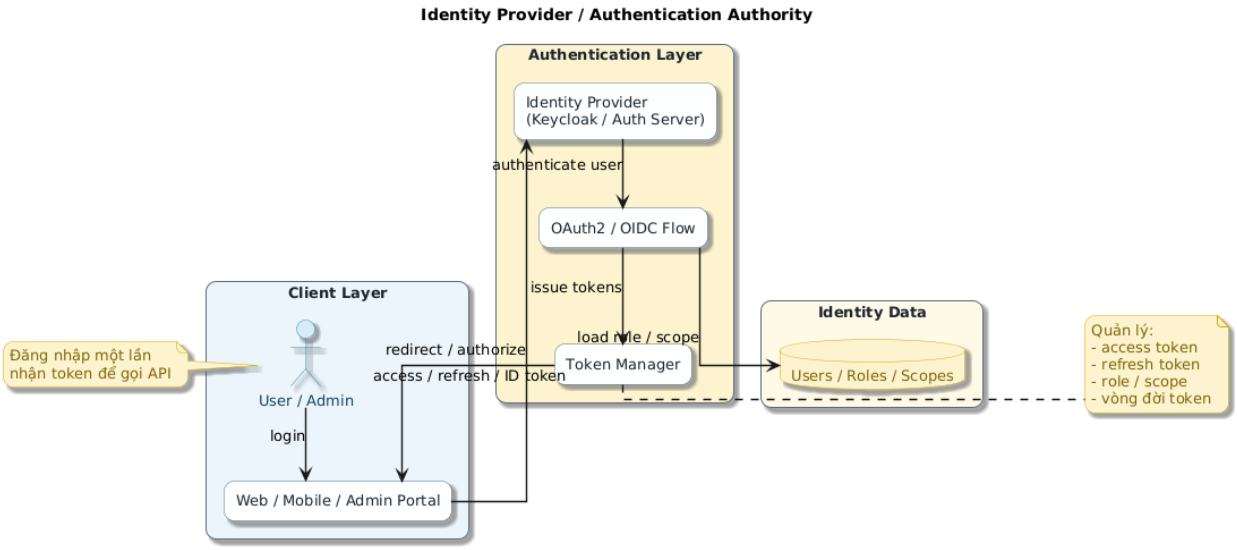


Hình 9. 4 - External Partner

9.5 Identity Provider / Authentication Authority

Identity Provider (IdP) hoặc Authentication Authority là thành phần chịu trách nhiệm xác thực người dùng và cấp phát danh tính số cho hệ thống. Thành phần này thực hiện các luồng xác thực theo OAuth2/OIDC, cấp access token, ID token, refresh token, đồng thời quản lý client, role, scope và vòng đời token. Trong kiến trúc của nhóm, vai trò này có thể được triển khai bằng các giải pháp như Keycloak. Đây là một bên liên quan cốt lõi vì toàn bộ cơ chế xác thực và

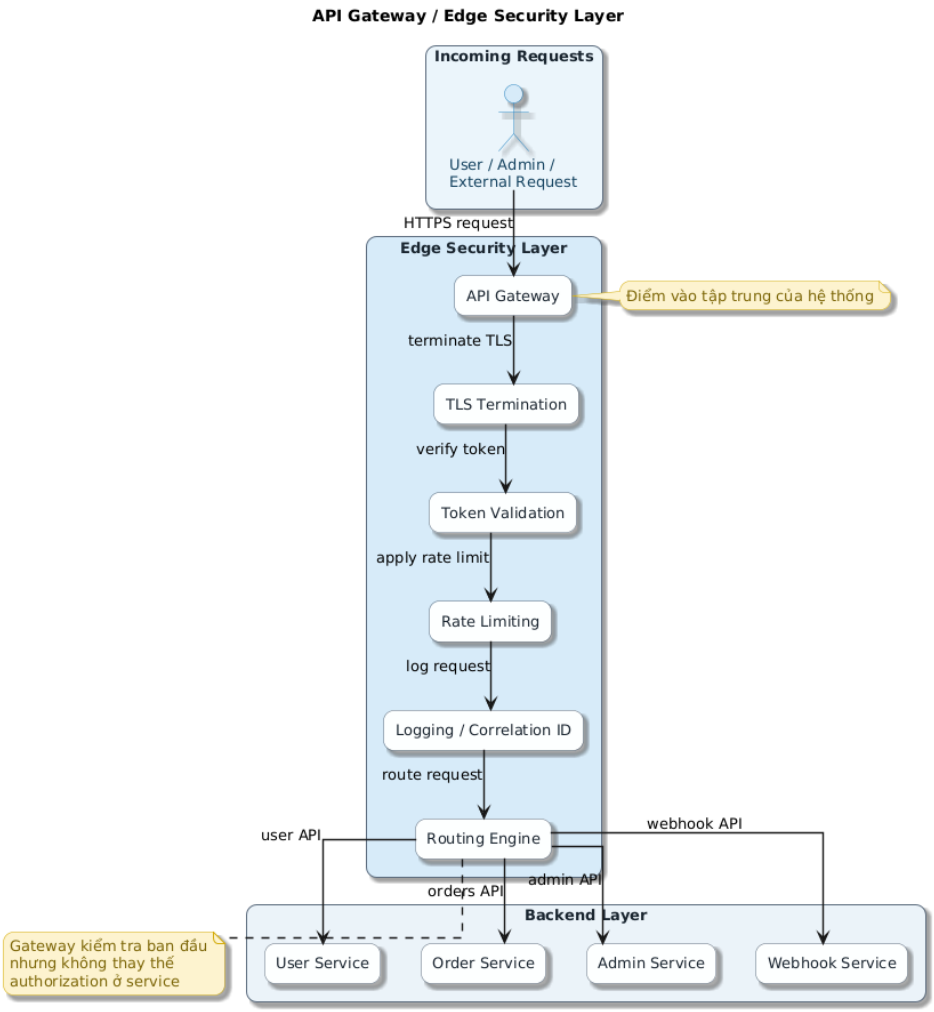
ủy quyền của hệ thống đều phụ thuộc vào tính đúng đắn và an toàn của thành phần này.



Hình 9. 5 - Identity Provider / Authentication Authority

9.6 API Gateway / Edge Security Layer

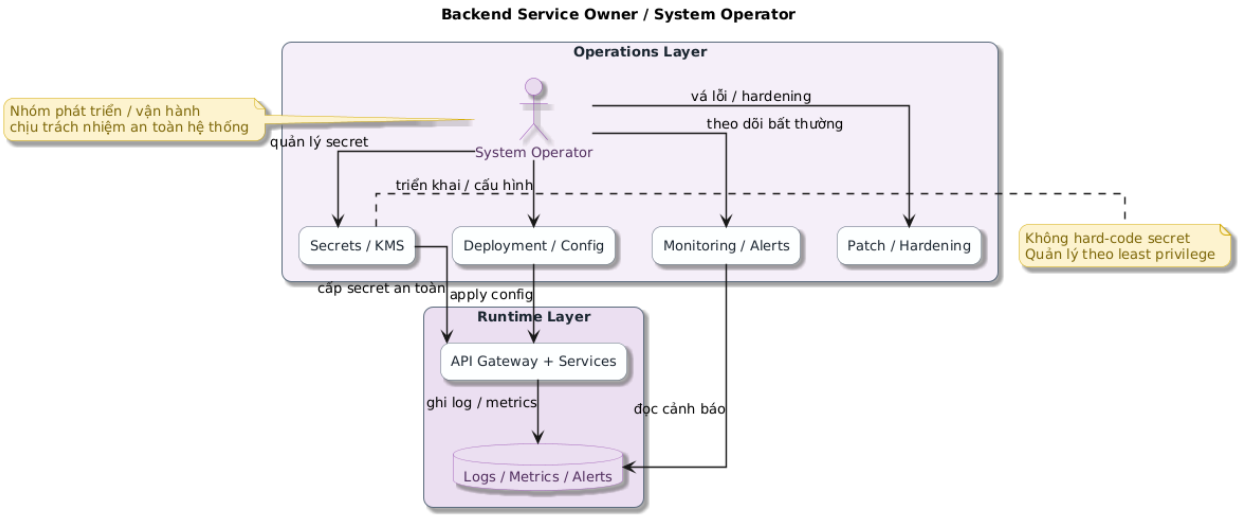
API Gateway hay Edge Security Layer là điểm vào tập trung của toàn bộ hệ thống API. Thành phần này tiếp nhận request từ bên ngoài, thực hiện các chức năng như TLS termination, token validation, rate limiting, logging, correlation ID, CORS policy và định tuyến request tới backend service tương ứng, đóng vai trò là lớp kiểm soát an ninh ở "cửa vào" của hệ thống, giúp chuẩn hóa các chính sách bảo vệ ở lớp biên. Tuy nhiên, gateway không thay thế hoàn toàn kiểm tra quyền ở tầng service, mà chỉ là lớp kiểm soát đầu tiên trong kiến trúc phòng thủ nhiều lớp.



Hình 9. 6 - API Gateway / Edge Security Layer

9.7 Backend Service Owner / System Operator

Backend Service Owner hoặc System Operator là nhóm phát triển và vận hành hệ thống, chịu trách nhiệm triển khai service, cấu hình gateway, quản lý secret, giám sát log, vá lỗi bảo mật và duy trì tính sẵn sàng của toàn hệ thống.
Đây là một bên liên quan rất quan trọng vì nhiều rủi ro bảo mật như lộ secret, cấu hình sai, thiếu logging hoặc kiểm soát quyền không đầy đủ thường phát sinh từ giai đoạn thiết kế và vận hành. Do đó, nhóm này không chỉ chịu trách nhiệm kỹ thuật mà còn giữ vai trò trung tâm trong việc bảo đảm hệ thống được triển khai và duy trì một cách an toàn.

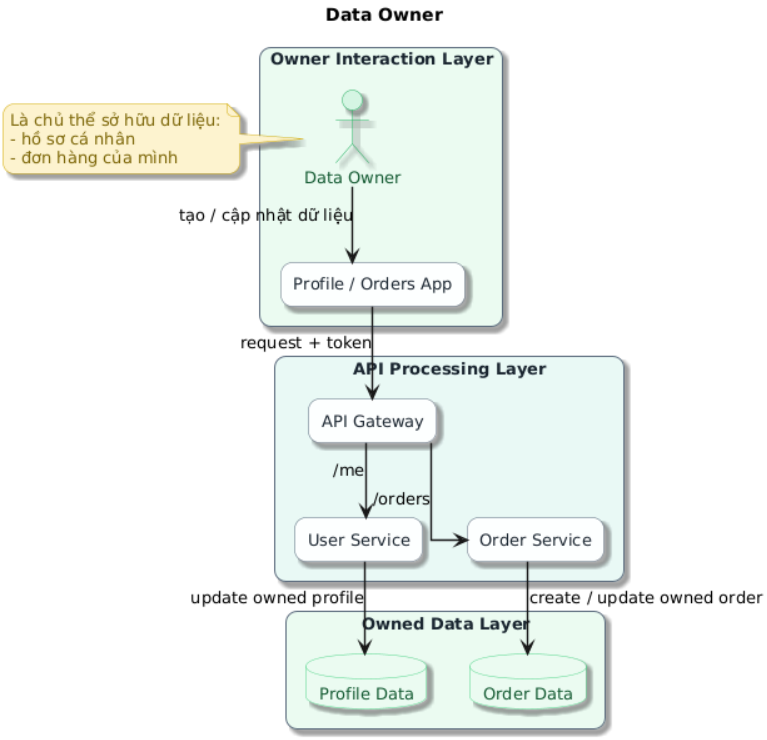


Hình 9. 7 - Backend Service Owner / System Operator

9.8 Data Owner

Data Owner là chủ thể sở hữu dữ liệu nghiệp vụ trong hệ thống. Trong ngữ cảnh của đồ án, Data Owner chủ yếu là người dùng cuối đối với dữ liệu hồ sơ cá nhân và các đơn hàng do chính họ tạo ra; trong một số trường hợp, doanh nghiệp hoặc quản trị viên cũng có thể là chủ thể quản lý dữ liệu hệ thống và dữ liệu vận hành.

Khái niệm Data Owner có ý nghĩa đặc biệt trong bài toán kiểm tra ownership nhằm chống BOLA, vì hệ thống phải xác định rõ ai là chủ sở hữu hợp pháp của từng đối tượng dữ liệu trước khi cho phép truy cập hoặc cập nhật.

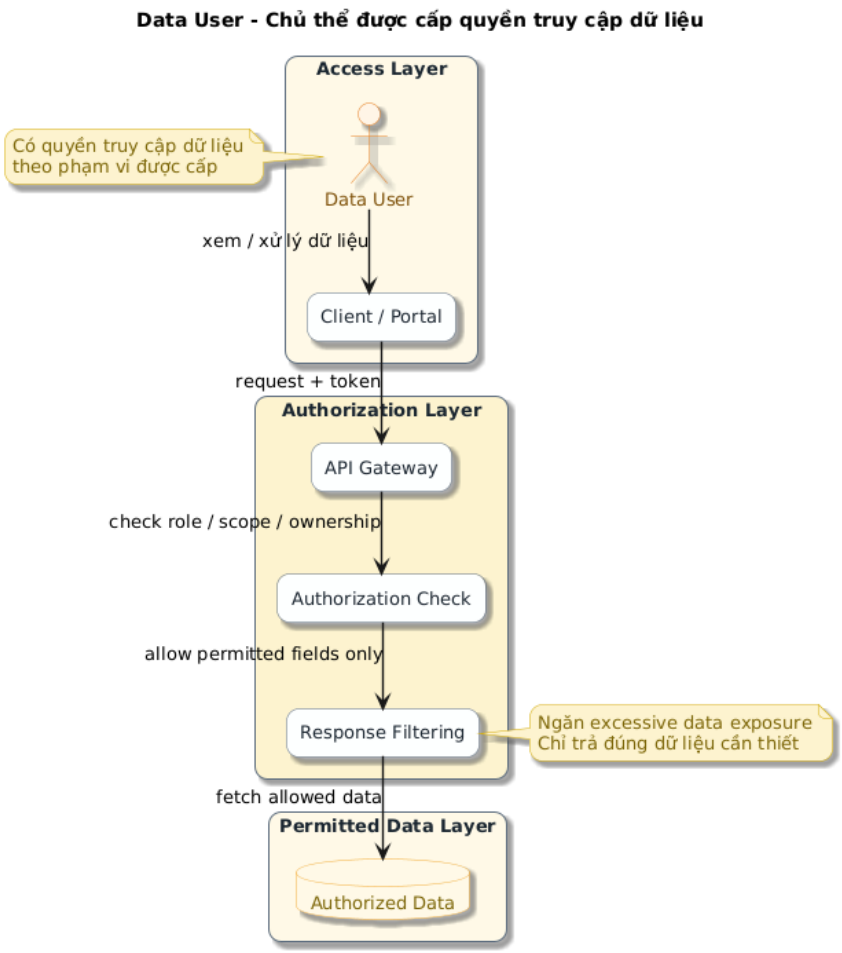


Hình 9. 8 - Data Owner

9.9 Data User

Data User là các chủ thể được phép xem, xử lý hoặc khai thác dữ liệu theo đúng phạm vi quyền hạn được cấp. Trong hệ thống này, Data User có thể là chính người dùng cuối khi truy cập dữ liệu của mình, quản trị viên khi xử lý dữ liệu ở phạm vi toàn cục theo vai trò, hoặc service nội bộ khi thao tác dữ liệu để phục vụ nghiệp vụ backend.

Vì vậy, Data User không phải lúc nào cũng là một nhóm hoàn toàn tách biệt với các actor khác, mà có thể là một vai trò sử dụng dữ liệu chồng lấp lên End User, Admin hoặc Internal Service. Mọi truy cập của Data User đều phải đi qua cơ chế authorization phù hợp.

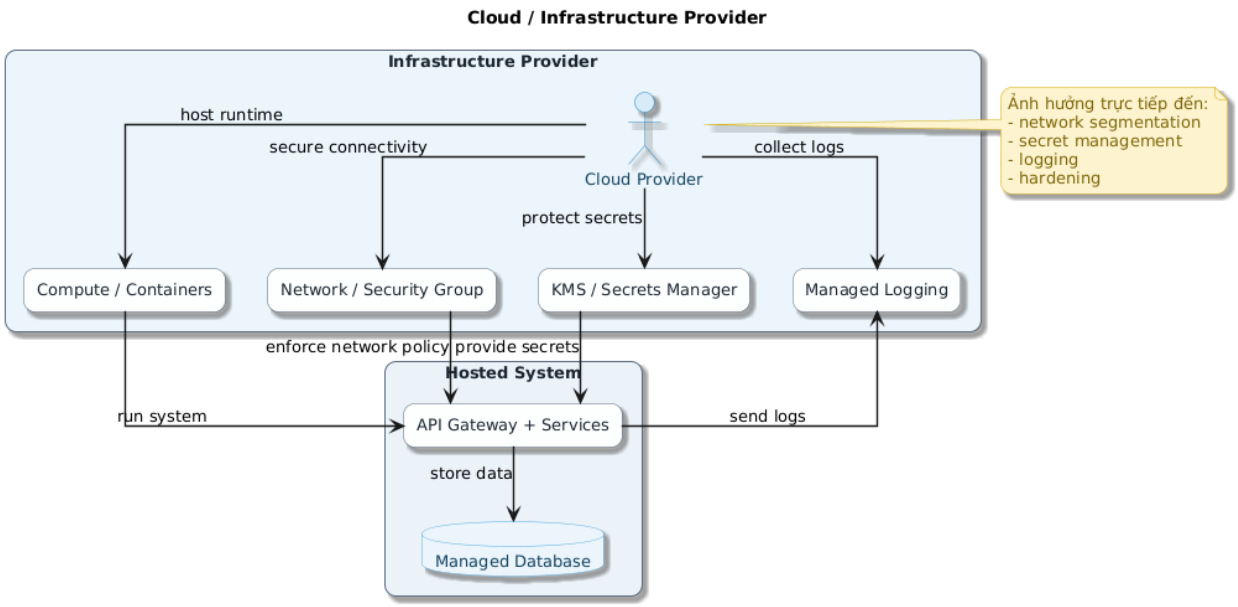


Hình 9. 9 - Data User

9.10 Cloud / Infrastructure Provider

Cloud / Infrastructure Provider là bên cung cấp hạ tầng triển khai hệ thống, bao gồm tài nguyên tính toán, mạng, cơ sở dữ liệu, hệ thống lưu trữ log, quản lý secret và các managed service nếu hệ thống chạy trên cloud.

Mặc dù nhà cung cấp hạ tầng không trực tiếp quyết định quyền truy cập nghiệp vụ của người dùng, nhưng lại ảnh hưởng rất lớn đến các yếu tố như network segmentation, firewall/security group, KMS/secrets management, lưu trữ audit log và khả năng hardening tổng thể của hệ thống. Vì vậy, đây là một bên liên quan gián tiếp nhưng có tác động mạnh đến mức độ an toàn của toàn bộ kiến trúc.



Hình 9. 10 - Cloud / Infrastructure Provider

10. Kiến trúc hệ thống

10.1 Kiến trúc tổng quan

Hệ thống được thiết kế theo mô hình API-first trên nền tảng cloud để phục vụ bài toán quản lý đơn hàng cho doanh nghiệp nhỏ. Trong kiến trúc này, các client như web, mobile và admin portal không gọi trực tiếp vào backend service mà phải đi qua một API Gateway đóng vai trò là điểm vào tập trung của toàn bộ hệ thống. Việc tổ chức theo mô hình này giúp chuẩn hóa luồng truy cập, tập trung các chính sách bảo mật tại lớp biên và hỗ trợ tốt hơn cho việc giám sát, kiểm soát truy cập và mở rộng hệ thống.

10.2 Các thành phần chính

10.2.1 Lớp Khách hàng (Client)

Lớp này bao gồm Web Client, Mobile Client và Admin Client. Đây là nơi người dùng cuối và quản trị viên tương tác với hệ thống. Người dùng cuối có thể đăng nhập, xem hồ sơ cá nhân, tạo đơn hàng, xem danh sách đơn hàng và xem chi tiết đơn hàng của chính mình. Quản trị viên sử dụng giao diện quản trị để quản lý người dùng, quản lý đơn hàng và theo dõi log hoặc audit của hệ thống.

10.2.2 Lớp Xác thực (Identity)

Việc xác thực người dùng được tách khỏi backend service và giao cho Identity Provider (IdP) xử lý theo chuẩn OAuth2/OIDC. Khi người dùng đăng nhập, client sẽ chuyển hướng đến IdP để xác thực. Sau khi xác thực thành công, IdP cấp access token, ID token và có thể kèm refresh token. Client sử dụng access token này để gọi API thông qua gateway. Cách thiết kế này giúp backend không phải trực tiếp xử lý username/password, đồng thời quản lý vai trò, scope và vòng đời token một cách tập trung.

10.2.3 Lớp API Gateway

API Gateway là lớp kiểm soát ở cửa vào của hệ thống. Gateway có nhiệm vụ tiếp nhận request từ client, thực hiện TLS termination, kiểm tra token, áp dụng rate limiting, ghi log và định tuyến request đến đúng backend service. Đây là lớp bảo vệ đầu tiên giúp giảm tải cho backend và tạo ra một điểm kiểm soát tập trung cho toàn bộ lưu lượng truy cập vào hệ thống.

10.2.4 Lớp Xử lý nghiệp vụ (Business Service)

Bao gồm các service chính như:

- User Service: xử lý các chức năng liên quan đến hồ sơ người dùng.
- Order Service: xử lý các chức năng tạo, xem danh sách và xem chi tiết đơn hàng.
- Admin Service: xử lý các API quản trị như quản lý người dùng, đơn hàng và log hệ thống.
- Webhook Service: tiếp nhận callback từ các đối tác bên ngoài như hệ thống thanh toán hoặc vận chuyển.

Mặc dù gateway đã thực hiện xác minh token, từng service vẫn phải tiếp tục kiểm tra authorization ở mức nghiệp vụ và mức tài nguyên. Điều này đặc biệt quan trọng đối với các API như GET /orders/{id}, nơi hệ thống phải kiểm tra xem đơn hàng được yêu cầu có thực sự thuộc về người dùng đang đăng nhập hay không, nhằm ngăn lỗ hổng Broken Object Level Authorization (BOLA).

10.2.5 Giao tiếp nội bộ giữa các service (Internal Service Communication)

Hệ thống không tái sử dụng access token của người dùng cuối mà sử dụng service identity riêng, ưu tiên theo cơ chế Client Credentials và có thể mở rộng sang mTLS. Cách tiếp cận này giúp phân tách rõ ranh giới tin cậy giữa người

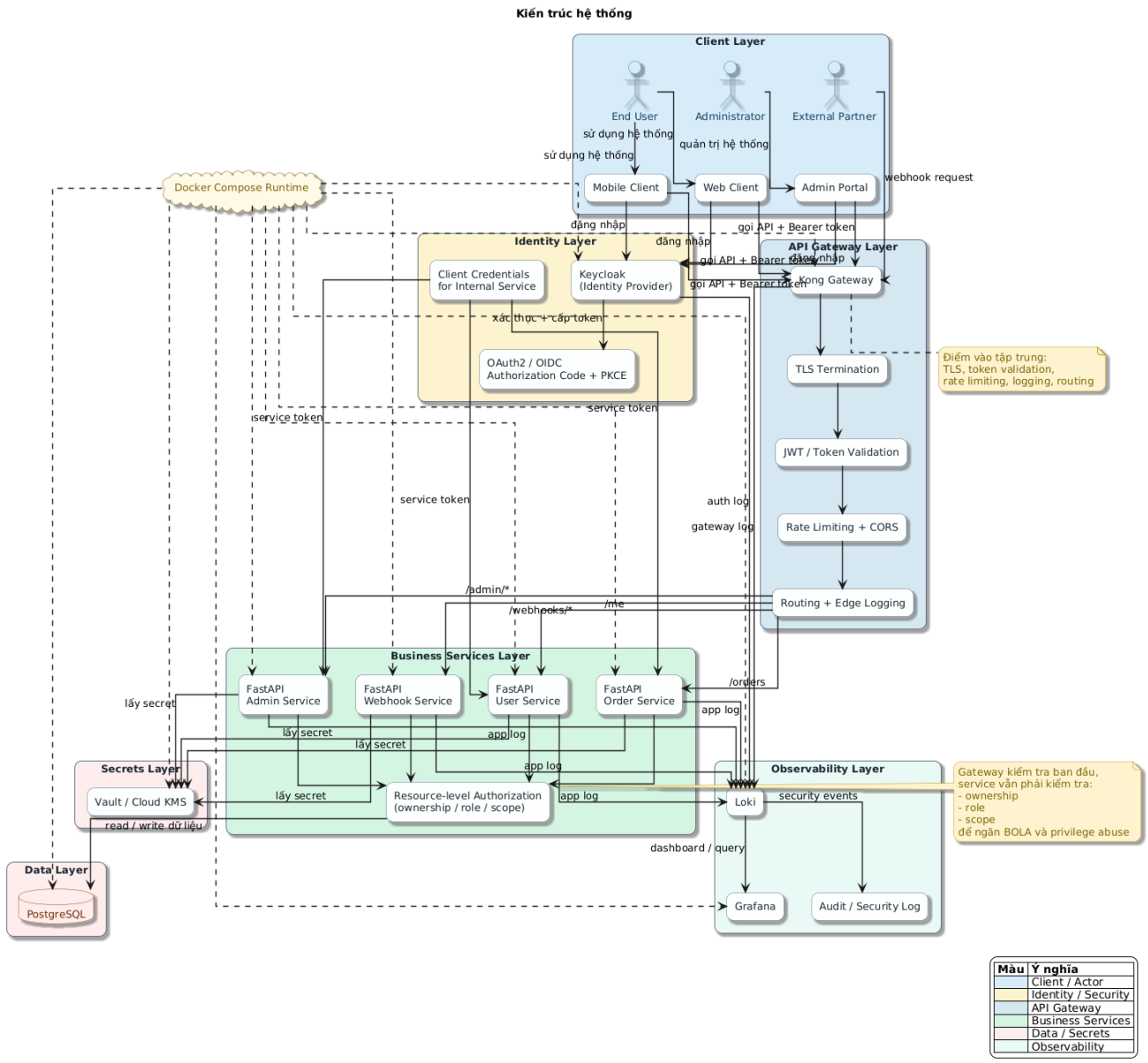
dùng và service nội bộ, hạn chế nguy cơ lạm dụng token và kiểm soát tốt hơn các luồng gọi API nội bộ.

10.2.6 Lớp Dữ liệu (Data Layer)

Hệ thống sử dụng một cơ sở dữ liệu trung tâm để lưu trữ dữ liệu người dùng, đơn hàng, log sự kiện và các dữ liệu nghiệp vụ khác. Về mặt logic, các service vẫn được tách trách nhiệm rõ ràng để thuận tiện cho kiểm soát quyền và audit, phù hợp với một mô hình PoC, đủ đơn giản để triển khai nhưng vẫn phản ánh đúng luồng bảo vệ dữ liệu trong hệ thống thực tế.

10.2.7 Logging, Audit và Secrets Management

Kiến trúc hệ thống có thêm lớp hỗ trợ bảo mật gồm Logging/Audit và Secrets Management. Logging/Audit phục vụ cho việc theo dõi request, truy vết sự kiện bảo mật và hỗ trợ điều tra sự cố. Các trường log quan trọng gồm *request_id/correlation_id*, *timestamp*, *subject*, *role/scope*, route, source IP, status code và quyết định allow/deny. Bên cạnh đó, các khóa, credentials và secret không được hard-code trong source code mà phải được lưu trong các cơ chế quản lý bí mật an toàn như Vault, KMS hoặc Secrets Manager.



Hình 10. 1 - Kiến trúc hệ thống

11. Tech Stack dự kiến

Thành phần	Công nghệ chọn	Mục tiêu lựa chọn
Backend framework	FastAPI	Phù hợp mô hình API-first, tự sinh OpenAPI/Swagger, hỗ trợ validation và triển khai nhanh JWT, OAuth2/OIDC, RBAC. Giúp nhóm tập trung hơn vào security testing và observability.

API Gateway	Kong	Dễ dựng bằng Docker, thuận tiện demo các lớp như JWT validation, rate limiting, logging, CORS và kết nối WAF. Phù hợp để trình bày luồng request qua từng lớp phòng thủ.
Identity Provider	Keycloak	Hỗ trợ rõ OAuth2/OIDC, PKCE, Client Credentials, role, scope và vòng đời token. Self-hosted, miễn phí, dễ minh họa các cơ chế xác thực/phân quyền trong đồ án.
Database	PostgreSQL	Phù hợp dữ liệu quan hệ như user, role, resource, audit event; đảm bảo nhất quán và dễ kiểm tra ownership/ACL để chống BOLA.
Logging / Monitoring	Grafana + Loki	Nhẹ, dễ triển khai local, hỗ trợ structured logging, correlation ID và dashboard trực quan khi demo các tình huống tấn công/xác thực lỗi.
Triển khai thử nghiệm	Docker Compose	Dựng toàn bộ stack local nhanh, dễ tái lập, thuận tiện cho demo và test bảo mật trong môi trường nhất quán.
Phân quyền mở rộng	OPA	Có thể mở rộng từ RBAC sang policy-based authorization rõ ràng, dễ giải thích và sát hơn với yêu cầu security nâng cao.
Secrets / Key Management	Vault	Hỗ trợ quản lý secrets/keys an toàn và rotation, phù hợp PoC local